Phishing Arena: A Multi-Agent LLM Tournament for Adversarial Email Security Research

Marco Stocco
Corso di Laurea Magistrale in Cybersecurity
Università degli studi di Padova
Padova, Italia

***Sommario*—Il phishing via email rimane uno dei vettori di attacco informatico più efficaci, con tassi di successo in crescita nonostante i progressi nei sistemi di difesa automatizzati. In questo lavoro presentiamo Phishing Arena, un framework di benchmark multi-agente basato su Large Language Models (LLM) progettato per studiare le dinamiche adversariali nella generazione e nel rilevamento di email di phishing in lingua italiana.**

Il sistema mette in competizione quattro modelli commerciali — `claude-sonnet-4-6`, `gpt-5.4-mini`, `deepseek-chat` e `grok-4-fast-non-reasoning` — in ruoli rotanti di PHISHER, FILTER e TARGET, su un torneo di 48 match e 949 round valutati. Il PHISHER è dotato di una *CampaignMemory* osservativa che accumula gli esiti dei round precedenti, abilitando un comportamento adattivo senza istruzioni prescrittive.

I risultati mostrano che `gpt-5.4-mini` è il modello più efficace nel ruolo PHISHER con un bypass rate del 12.9% e un trend adattivo crescente (+6.8 punti percentuali tra prima e seconda metà del torneo), mentre `claude-sonnet-4-6` eccelle come FILTER con il tasso di falsi positivi più basso (0.7%) e un'accuracy del 98.3%. Un finding critico emerge dall'analisi dei bypass riusciti: il 79% non è attribuibile a tecniche di evasione tecnica esplicite, ma alla plausibilità contestuale dell'email — un risultato con implicazioni dirette per la progettazione dei sistemi di difesa reali.

Parole chiave: phishing, large language models, sicurezza informatica, red teaming automatizzato, benchmark adversariale, email security.

I. INTRODUZIONE

Il phishing via email rappresenta ancora oggi uno dei principali vettori di compromissione nelle organizzazioni, responsabile di oltre il 36% delle violazioni dei dati a livello globale [1]. Nonostante i significativi progressi nei sistemi di filtraggio automatizzato, la natura evolutiva degli attacchi — sempre più personalizzati e contestualmente plausibili — rende il problema aperto e urgente.

L'avvento dei Large Language Models (LLM) ha introdotto una duplice tensione nel panorama della sicurezza email: da un lato, questi modelli possono essere impiegati per generare email di phishing altamente convincenti e personalizzate su scala; dall'altro, possono potenziare i sistemi di rilevamento con capacità di comprensione linguistica e contestuale senza precedenti. Comprendere quale dei due lati prevalga — e in quali condizioni — è una questione di rilevanza pratica e scientifica immediata.

La letteratura esistente ha affrontato questi due aspetti prevalentemente in modo separato: studi sulla generazione di phishing tramite LLM [2], [3] e studi sul rilevamento [4], [5] operano in isolamento, senza considerare la dinamica adversariale emergente quando generazione e rilevamento interagiscono in un sistema chiuso. Mancano inoltre benchmark sistematici che confrontino più modelli LLM commerciali in ruoli multipli su un corpus in lingua italiana, nonostante il contesto linguistico e culturale sia riconosciuto come fattore rilevante nell'efficacia degli attacchi di social engineering.

Contributi. In questo lavoro presentiamo **Phishing Arena**, un framework di torneo multi-agente che affronta queste lacune con i seguenti contributi originali:

- Un'architettura a tre ruoli (PHISHER, FILTER, TARGET) che simula l'intera catena di attacco, dalla generazione alla reazione dell'utente finale, in un ambiente controllato e ripetibile.
- Una *CampaignMemory* osservativa che permette al PHISHER di adattare la strategia di attacco in base agli esiti dei round precedenti, senza istruzioni prescrittive che potrebbero introdurre bias sperimentali.
- Un dataset stratificato di 12 archetipi professionali italiani con livelli di familiarità cyber variabili, corredato da 600 email legittime contestualizzate (50 per archetipo).
- Un'analisi comparativa sistematica di quattro LLM commerciali su 48 match e 949 round valutati, con metriche di bypass rate, accuracy del filter, click probability e learning curve adattiva.
- Il finding che i bypass riusciti sono prevalentemente attribuibili alla plausibilità contestuale delle email piuttosto che a tecniche di evasione tecnica — un risultato con implicazioni dirette per i sistemi di difesa reali.

Il resto del paper è organizzato come segue. La Sezione II discute il lavoro correlato. La Sezione III descrive l'architettura del sistema. La Sezione IV presenta la configurazione sperimentale. La Sezione V riporta i risultati. La Sezione VI discute le implicazioni. La Sezione VII delinea il lavoro futuro. La Sezione VIII conclude.

II. LAVORO CORRELATO

A. LLM per la Generazione di Phishing

Hazell [2] ha dimostrato che GPT-4 è in grado di generare email di spear phishing altamente personalizzate a costi marginali, riducendo drasticamente la barriera di ingresso per gli attaccanti. Karanjai [3] ha mostrato come i modelli linguistici possano sfruttare informazioni OSINT per contestualizzare gli

attacchi a specifici profili professionali. Heiding et al. [6] hanno confrontato la capacità di GPT-4 di generare phishing credibile rispetto a email create manualmente da esperti, trovando prestazioni comparabili in termini di tasso di click.

B. LLM per il Rilevamento di Phishing

Sul versante difensivo, Koide et al. [4] hanno proposto l'uso di LLM come classificatori zero-shot per il rilevamento di phishing, mostrando performance superiori ai sistemi basati su regole. Greshake et al. [5] hanno evidenziato la vulnerabilità dei sistemi LLM-based a prompt injection attraverso contenuti malevoli embeddati nelle email stesse. Salahdine e Kaabouch [7] hanno fornito una tassonomia sistematica delle tecniche di social engineering rilevanti per il phishing.

C. Red Teaming Automatizzato con LLM

Il concetto di arena multi-agente per la valutazione adversariale è stato esplorato da Perez et al. [8] nel contesto del red teaming di LLM, dove un modello attaccante tenta di elicitare output dannosi da un modello difensore. Chao et al. [9] hanno formalizzato il problema del jailbreaking come ottimizzazione adversariale tra due agenti. Il nostro approccio si distingue per l'applicazione al dominio specifico del phishing email, l'introduzione di un terzo agente (TARGET) e il meccanismo di memoria osservativa.

D. Posizionamento

Rispetto alla letteratura, Phishing Arena introduce tre elementi di novità: (1) la valutazione simultanea di più LLM in ruoli multipli e rotanti, (2) un feedback loop adattivo basato su memoria osservativa anziché ottimizzazione esplicita, e (3) un corpus in lingua italiana che riflette le specificità linguistiche e culturali del contesto europeo. A nostra conoscenza, non esistono benchmark analoghi per la lingua italiana.

III. ARCHITETTURA DEL SISTEMA

A. Visione d'Insieme

Phishing Arena simula un ciclo completo di attacco phishing in un ambiente di laboratorio controllato. Ogni *match* coinvolge tre agenti LLM in ruoli distinti: il PHISHER genera email di phishing contestualizzate, il FILTER classifica ogni email come phishing o legittima, e il TARGET simula la reazione comportamentale di un professionista reale qualora l'email sfugga al filtraggio.

La Figura 1 illustra il flusso complessivo di un round.

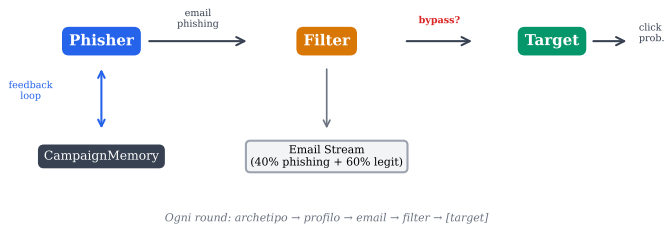

Figura 1: Architettura di Phishing Arena. In ogni round, il PHISHER genera un'email contestualizzata sul profilo target; il FILTER valuta l'email dallo stream misto; il TARGET reagisce solo in caso di bypass. La *CampaignMemory* accumula gli esiti per il feedback loop adattivo.

B. I Tre Ruoli

PHISHER. Riceve un profilo target sintetico e la memoria osservativa della campagna corrente. Produce un'analisi del vettore di attacco (`step1`) e l'email di phishing (`step2`) in formato JSON strutturato. Il prompt segue un framing di red teaming accademico per minimizzare i rifiuti dei sistemi di sicurezza dei provider.

FILTER. Opera in modalità *blind*: non conosce le tecniche specifiche che il PHISHER può impiegare. Valuta ogni email basandosi esclusivamente sui segnali visibili — anomalie nel mittente, coerenza del link, urgenza eccessiva, leve psicologiche — senza un vocabolario di tecniche prescritto. Questa scelta metodologica è cruciale: un filter consapevole delle tecniche specifiche del phisher misurerebbe pattern matching, non capacità di rilevamento genuina.

TARGET. Riceve il profilo sintetico dell'utente e l'email che ha superato il filter. Simula la reazione comportamentale restituendo una click probability (0–100), un'analisi emotiva e cognitiva, e un'azione discreta (click, ignora, segnala, risponde, elimina).

C. CampaignMemory

La *CampaignMemory* è il meccanismo di feedback loop del PHISHER. Parte vuota al round 1 — garantendo una baseline pura senza bias — e si arricchisce organicamente ad ogni round phishing completato, registrando: archetipo target, sintesi dell'email inviata, verdetto del filter, segnali rilevati, esito (bypass/bloccata), e click probability se disponibile.

```
class CampaignMemory:
    def add_round(self, round_num, target_summary,
                  email_summary, filter_verdict,
                  filter_signals, phishing_bypassed,
                  target_comment=None,
                  click_probability=None):
        self.rounds.append({
            "round": round_num,
            "target_summary": target_summary,
            "email_summary": email_summary,
            "filter_verdict": filter_verdict,
            "filter_signals": filter_signals,
            "phishing_bypassed": phishing_bypassed,
            "target_comment": target_comment,
            "click_probability": click_probability
```

```
})
```

Listing 1: Struttura della CampaignMemory. La memoria è osservativa: descrive esiti senza prescrivere strategie.

Il diario osservativo viene serializzato in linguaggio naturale e preposto al messaggio utente del PHISHER ad ogni round successivo al primo, consentendo al modello di adattare la strategia sulla base degli esiti reali.

D. Email Stream Stratificato

Lo stream email mescola email phishing generate dinamicamente con email legittime contestualizzate. Le email legittime sono organizzate in 12 pool separati, uno per ciascun archetipo professionale (Tabella I). Ad ogni round viene estratto un archetipo tramite un sistema a *mazzo di carte* che garantisce copertura uniforme prima di ripetere.

Tabella I: Archetipi professionali e livelli di familiarità cyber.

Ruolo	Settore	Familiarità
CEO	PMI generica	Bassa
CFO	Manifatturiero	Bassa
HR Manager	Tech	Media
IT Manager	Logistica	Alta
Responsabile IT	Bancario	Alta
Responsabile Acquisti	Retail	Bassa
Direttore Marketing	E-commerce	Media
Commerciale	Assicurazioni	Bassa
Avvocato	Studio legale	Media
Contabile	Studio commercialista	Bassa
Office Manager	Consulenza	Bassa
Titolare	Ristorante/Hospitality	Molto bassa

E. Agenti LLM

Il torneo coinvolge quattro modelli commerciali selezionati per diversità di provider, architettura e posizionamento di mercato (Tabella II).

Tabella II: Agenti LLM nel torneo. Prezzi verificati ad aprile 2026.

Modello	Provider	In ($/1M)	Out ($/1M)
claude-sonnet-4-6	Anthropic	3.00	15.00
gpt-5.4-mini	OpenAI	0.75	4.50
deepseek-chat	DeepSeek	0.27	1.10
grok-4-fast-non-reasoning	xAI	0.20	0.50

F. Design dei Prompt

I system prompt dei tre ruoli seguono principi distinti e deliberati.

Il PHISHER riceve istruzioni esplicite sulle tecniche di costruzione del link malevolo (subdomain spoofing, typosquatting, keyword domain, combo brand+TLD) e sul processo a due step di analisi + generazione. Questo massimizza la qualità delle email prodotte e consente di studiare la capacità dei modelli di ragionare strategicamente sull'attacco.

Il FILTER è progettato *blind*: il prompt descrive un comportamento realistico ma non enumera le categorie di tecniche da cercare. La scelta è metodologicamente necessaria — un filter che conosce il vocabolario del phisher misura pattern matching, non capacità di rilevamento genuina. Questo è uno dei principali accorgimenti che differenziano Phishing Arena dai benchmark esistenti.

Il TARGET riceve il profilo completo dell'utente sintetico e valuta l'email in prima persona, con istruzioni esplicite a calibrare l'analisi del link sul proprio livello dichiarato di familiarità cyber.

IV. CONFIGURAZIONE SPERIMENTALE

A. Parametri del Torneo

Il torneo è configurato con i parametri in Tabella III. Con 4 agenti, le permutazioni di 3 elementi senza ripetizione producono $P(4, 3) = 24$ combinazioni di ruoli, replicate 2 volte per robustezza statistica, per un totale di 48 match.

Tabella III: Parametri di configurazione del torneo.

Parametro	Valore
Round per match	20
Phishing ratio (target)	0.40
Ripetizioni per coppia	2
Match totali	48
Round attesi	960
Round valutati	949
Copertura	98.9%

B. Metriche

Per il PHISHER misuriamo il *bypass rate* — frazione di round phishing in cui il FILTER classifica erroneamente l'email come legittima — e la *click probability media* sui round con esposizione target. Per il FILTER misuriamo accuracy, recall phishing e false positive rate sulla confusion matrix aggregata. Per il TARGET misuriamo click probability media, mediana e distribuzione delle azioni discrete. La *learning curve* misura il bypass rate per finestre di 5 round phishing consecutivi, confrontando prima e seconda metà del torneo.

C. Affidabilità e Riproducibilità

Il framework implementa checkpoint automatici dopo ogni match completato, consentendo il resume in caso di interruzione. Ogni agente utilizza exponential backoff con 5 tentativi (delay: 2, 5, 15, 30, 60 secondi) per gestire errori transitori delle API. Il codice completo è disponibile pubblicamente all'indirizzo https://github.com/Krabby24/phishing-arena.

V. RISULTATI

A. Leaderboard Phisher

La Tabella IV riporta le performance aggregate dei quattro modelli nel ruolo PHISHER.

Tabella IV: Leaderboard Phisher. Ordinata per bypass rate decrescente.

Modello	Match	R.Ph.	Bypass	Rate	CP media
gpt-5.4-mini	12	85	11	**12.9%**	41.1
claude-sonnet-4-6	12	96	4	4.2%	65.8
deepseek-chat	12	96	4	4.2%	23.2
grok-4-fast-non-reasoning	12	89	0	0.0%	N/A

R.Ph. = Round phishing; CP = Click probability

`gpt-5.4-mini` è il modello più efficace nel ruolo PHISHER, con un bypass rate di 12.9% (11/85 round phishing). Claude e DeepSeek mostrano performance equivalenti (4.2%), mentre Grok non ottiene alcun bypass in 89 round phishing. È rilevante notare che Claude, pur con bypass rate inferiore, ottiene la click probability media più alta (65.8) sui 4 bypass riusciti — suggerendo che quando riesce a eludere il filter produce email particolarmente convincenti per il target.

`gpt-5.4-mini` è anche l'unico modello a manifestare errori nel ruolo Phisher: 11 `phisher_failed` (12.9% dei round phishing), tutti attribuibili a rifiuti del sistema di sicurezza del provider per contenuto adversariale. Questo introduce un bias metodologico discusso nella Sezione VI.

B. Leaderboard Filter

La Tabella V riporta le performance nel ruolo FILTER, con la confusion matrix aggregata su tutti i match.

Tabella V: Leaderboard Filter con confusion matrix aggregata.

Modello	Val.	TP	TN	FP	FN	Acc.	Rec.	FPR
claude-sonnet-4-6	236	86	146	1	3	**98.3%**	96.6%	**0.7%**
gpt-5.4-mini	240	94	141	4	1	97.9%	**98.9%**	2.8%
deepseek-chat	237	87	137	6	7	94.5%	92.6%	4.2%
grok-4-fast-non-reasoning	236	71	138	10	8	92.1%	89.9%	6.8%

Val. = Round valutati; Acc. = Accuracy; Rec. = Recall phishing; FPR = False positive rate

Claude e OpenAI si collocano al vertice con profili complementari: Claude minimizza i falsi positivi (FPR 0.7%, 1 solo FP su 147 email legittime), mentre OpenAI massimizza il recall phishing (98.9%, 1 solo FN su 95 email phishing). DeepSeek e Grok mostrano performance inferiori, con FPR crescente (4.2% e 6.8% rispettivamente) e recall decrescente.

C. Analisi del Target

Il TARGET viene attivato solo in caso di bypass — 19 esposizioni totali in tutto il torneo. Il campione limitato impone cautela nell'interpretazione (Tabella VI).

Tabella VI: Leaderboard Target. Solo round post-bypass (n=19 totali).

Modello	Esp.	CP media	Azione più freq.
grok-4-fast-non-reasoning	8	**50.0**	click_link (50%)
deepseek-chat	7	38.6	click_link (43%)
claude-sonnet-4-6	2	35.0	misto
gpt-5.4-mini	2	34.0	misto

Esp. = Esposizioni; CP = Click probability

D. Analisi Heatmap

La Figura 2 mostra la heatmap del bypass rate per ogni combinazione Phisher × Filter.

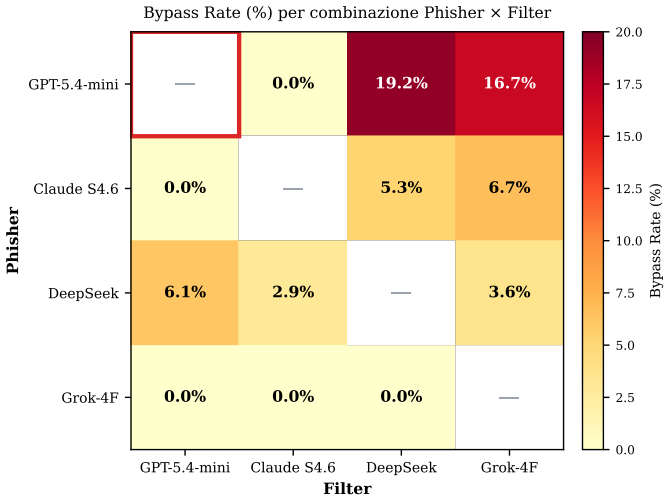

Figura 2: Heatmap bypass rate (%) per combinazione Phisher × Filter. Le celle sulla diagonale sono assenti (stesso agente non può ricoprire due ruoli). La combinazione `gpt-5.4-mini` → `deepseek-chat` mostra il bypass rate più alto (19.2%).

La combinazione più critica è `gpt-5.4-mini` → `deepseek-chat` con bypass rate del 19.2% (5/26 round phishing), seguita da `gpt-5.4-mini` → `grok-4-fast-non-reasoning` con il 16.7% (5/30). Entrambe le combinazioni coinvolgono `gpt-5.4-mini` come PHISHER, confermando la sua superiorità nel ruolo adversariale.

E. Learning Curve Adattiva

La Figura 3 mostra le learning curve aggregate per phisher.

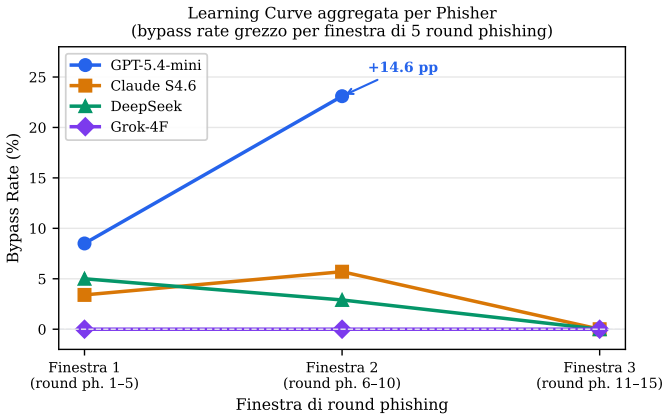

Figura 3: Learning curve aggregata per PHISHER. Bypass rate medio per finestra di 5 round phishing consecutivi. Solo `gpt-5.4-mini` mostra un trend adattivo crescente statisticamente rilevante.

`gpt-5.4-mini` è l'unico modello a mostrare un trend chiaramente crescente: dal 8.5% nella prima finestra al 23.1% nella seconda (+14.6 punti percentuali in valore grezzo). Claude

e DeepSeek mostrano variazioni marginali o decrescenti, Grok rimane stabile a zero.

F. Caratterizzazione dei Bypass

L'analisi delle `tecnica_identificata` nei bypass riusciti rivela un finding centrale: il 79% dei bypass (15/19) è classificato dal FILTER come privo di tecnica evidente — l'email appare come una comunicazione operativa standard. Solo il 21% rimanente mostra segnali tecnici identificabili.

Questo suggerisce che i bypass riusciti in Phishing Arena non sono attribuibili a tecniche di evasione tecnica sofisticate, ma alla capacità del PHISHER di generare email contestualmente plausibili che non attivano i pattern di rilevamento del FILTER. Le implicazioni per i sistemi di difesa reali sono discusse nella Sezione VI.

G. Analisi di Stabilità

Confrontando le due ripetizioni di ciascun match (24 coppie), la differenza media assoluta del bypass rate è di 5.45 punti percentuali (mediana: 0.0 pp). Il 58% delle coppie (14/24) mostra bypass rate identico tra le due ripetizioni; il 29% (7/24) mostra una differenza superiore a 10 pp. Il caso più instabile è `deepseek-chat` → `claude-sonnet-4-6` → `grok-4-fast-non-reasoning`, con 0.0% nella prima ripetizione e 20.0% nella seconda.

VI. DISCUSSIONE

A. Perché OpenAI Bypassa Meglio

La superiorità di `gpt-5.4-mini` nel ruolo PHISHER può essere attribuita a due fattori concorrenti. Primo, il modello dimostra una capacità superiore di sfruttare le informazioni contestuali del profilo target nella costruzione dell'email — un'ipotesi supportata dalla click probability media elevata di Claude come target (65.8) quando esposto a bypass di OpenAI. Secondo, il trend adattivo crescente (+14.6 pp tra prima e seconda finestra) suggerisce un utilizzo più efficace della *CampaignMemory*: il modello apprende dagli esiti passati e modifica la strategia in modo osservabile.

Tuttavia, `gpt-5.4-mini` è anche l'unico modello a manifestare errori sistematici nel ruolo PHISHER (11 `phisher_failed`, pari al 12.9% dei round phishing). Questi errori, attribuibili ai sistemi di sicurezza del provider, introducono un bias: i round in cui il modello rifiuta di generare l'email non contribuiscono né positivamente né negativamente al bypass rate, ma riducono il campione effettivo.

B. Perché Grok Non Bypassa

`grok-4-fast-non-reasoning` ottiene 0 bypass in 89 round phishing. Un'analisi qualitativa delle email generate suggerisce che il modello tenda a produrre email con leve psicologiche generiche e link meno contestualizzati, riducendo la plausibilità per profili specifici. La denominazione *non-reasoning* nel nome del modello è coerente con questa interpretazione: la costruzione di email di phishing efficaci richiede ragionamento multi-step sul profilo target, che modelli non-reasoning potrebbero eseguire in modo meno approfondito.

C. Il Finding Centrale: Plausibilità vs. Tecnica

Il risultato più rilevante del torneo è che il 79% dei bypass non è attribuibile a tecniche di evasione tecnica identificabili. Questo ha implicazioni dirette per i sistemi di difesa: i filtri che si concentrano sul riconoscimento di pattern tecnici noti (subdomain spoofing, typosquatting, ecc.) potrebbero essere insufficienti contro attacchi che puntano alla plausibilità contestuale. Un sistema di rilevamento efficace deve incorporare comprensione del contesto lavorativo del destinatario — una capacità che solo i modelli linguistici avanzati possono fornire.

D. Limitazioni

Phishing ratio artificialmente elevato. Il ratio configurato (0.40) supera significativamente la distribuzione reale del phishing nel traffico email (stimata all'1–5% [1]). Questa scelta massimizza il numero di osservazioni avversariali per match, ma non riflette le condizioni operative reali. I risultati del FILTER vanno interpretati come performance in condizioni di stress test, non come stima dell'efficacia operativa.

Campione Target limitato. Le 19 esposizioni totali del TARGET — conseguenza diretta del basso bypass rate complessivo — rendono le statistiche di click probability e distribuzione delle azioni non robuste statisticamente. La leaderboard Target va interpretata come dato esplorativo.

Granularità della learning curve. Con un ratio di 0.40 su 20 round, ogni match produce mediamente 8 round phishing, che generano 1–2 finestre nella learning curve. La granularità è insufficiente per analisi statistiche robuste del trend adattivo a livello di singolo match; l'aggregazione su tutti i match dello stesso phisher mitiga parzialmente questo limite.

Non-indipendenza dei round. La *CampaignMemory* accumula feedback cross-archetipo: al round 10, il PHISHER ha memoria di fino a 9 target con profili eterogenei. Questo introduce una dipendenza potenziale tra round che non è modellata nell'analisi statistica.

Assenza di baseline. Il benchmark confronta LLM tra loro ma non include una baseline non-LLM (es. template-based phisher). Senza questa riferimento è difficile quantificare il contributo incrementale dei modelli linguistici rispetto ad approcci più semplici.

VII. LAVORO FUTURO

Diversi filoni di ricerca emergono naturalmente da questo lavoro.

Confronto cross-linguistico. Un rerun del torneo in lingua inglese consentirebbe di isolare l'effetto della lingua sulla capacità adversariale dei modelli, separando le performance intrinseche dai bias linguistici. Dati preliminari suggeriscono che la plausibilità contestuale potrebbe variare significativamente tra italiano e inglese per profili aziendali europei.

Baseline non-LLM. Introdurre un PHISHER basato su template fissi consentirebbe di quantificare il contributo incrementale dei LLM rispetto ad approcci tradizionali, fornendo un punto di riferimento per l'interpretazione del bypass rate.

Aumento dei round. Portare `rounds_per_match` a 30–50 produrrebbe learning curve più granulari (3–4 finestre invece

di 1–2) e consentirebbe analisi statistiche più robuste del trend adattivo.

Memoria del Target. Il TARGET attuale non ha memoria inter-round — ogni esposizione è indipendente. Introdurre una memoria del target che simuli l'effetto di formazione sulla sicurezza (aumento della soglia di click dopo bypass ripetuti) arricchirebbe il realismo del modello.

Dataset da email reali. Le email legittime attuali sono generate sinteticamente. Un dataset costruito su email aziendali reali anonimizzate aumenterebbe la validità esterna dell'esperimento.

VIII. CONCLUSIONE

Abbiamo presentato Phishing Arena, un framework di benchmark multi-agente che impiega LLM commerciali per studiare le dinamiche adversariali nel phishing email in lingua italiana. Il torneo di 48 match e 949 round valutati ha prodotto risultati chiari e replicabili.

`gpt-5.4-mini` si afferma come il modello più efficace nel ruolo adversariale, con bypass rate del 12.9% e un trend adattivo crescente che evidenzia l'efficacia del feedback loop della *CampaignMemory*. `claude-sonnet-4-6` eccelle nella difesa, con il tasso di falsi positivi più basso (0.7%) mantenendo un'accuracy del 98.3%.

Il finding più rilevante — che il 79% dei bypass riusciti è attribuibile alla plausibilità contestuale piuttosto che a tecniche di evasione tecnica — ha implicazioni dirette per la progettazione dei sistemi di difesa: la comprensione del contesto è tanto importante quanto il riconoscimento dei pattern tecnici.

Phishing Arena è, a nostra conoscenza, il primo benchmark di questo tipo per la lingua italiana e fornisce una metodologia riproducibile per la valutazione comparativa di LLM in scenari di sicurezza adversariale.

RINGRAZIAMENTI

L'autore ringrazia i provider delle API utilizzate (Anthropic, OpenAI, DeepSeek, xAI) per l'accesso ai modelli. Il framework è stato sviluppato con il supporto di Claude (Anthropic) come strumento di sviluppo e analisi.

RIFERIMENTI BIBLIOGRAFICI

[1] Verizon, "2024 data breach investigations report," Verizon Business, Tech. Rep., 2024. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/

[2] J. Hazell, "Spear phishing with large language models," *arXiv preprint arXiv:2305.06972*, 2023.

[3] R. Karanjai, "Targeted phishing campaigns using large scale language models," *arXiv preprint arXiv:2301.00665*, 2022.

[4] T. Koide, N. Fukushi, H. Nakano, and D. Chiba, "Detecting phishing sites using ChatGPT," in *arXiv preprint arXiv:2306.05816*, 2024.

[5] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," in *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security*, 2023, pp. 79–90.

[6] F. Heiding, B. Schneier, A. Vishwanath, J. Bernstein, and P. S. Park, "Devising and detecting phishing: Large language models vs. smaller human models," in *IEEE Access*, vol. 12, 2024, pp. 42 131–42 146.

[7] F. Salahdine and N. Kaabouch, "Social engineering attacks: A survey," *Future Internet*, vol. 11, no. 4, p. 89, 2019.

[8] E. Perez, S. Huang, F. Song, T. Cai, R. Ring, J. Aslanides, A. Glaese, N. McAleese, and G. Irving, "Red teaming language models with language models," in *arXiv preprint arXiv:2202.03286*, 2022.

[9] P. Chao, A. Robey, E. Dobriban, H. Hassani, G. J. Pappas, and E. Wong, "Jailbreaking black box large language models in twenty queries," in *arXiv preprint arXiv:2310.08419*, 2023.

APPENDICE

Di seguito un esempio annotato della struttura JSON di un round completo con bypass riuscito.

```
{
  "round": 7,
  "archetipo": {
    "ruolo": "Commerciale",
    "settore": "assicurazioni",
    "familiarita_cyber": "bassa"
  },
  "is_actually_phishing": true,
  "filter_result": {
    "verdetto": "LEGIT",        // bypass!
    "confidence": 35,
    "tecnica_identificata": "nessuna tecnica
        evidente"
  },
  "phishing_bypassed": true,
  "target_result": {
    "click_probability": 80,
    "azione": "click_link",
    "valutazione_link": "Il link sembra..."
  },
  "memory_size_at_round": 3
}
```

Listing 2: Struttura JSON di un round con bypass.

I system prompt completi dei tre ruoli sono disponibili nel repository pubblico del progetto all'indirizzo https://github.com/Krabby24/phishing-arena.

Di seguito le versioni sintetiche che illustrano le scelte progettuali chiave.

Il FILTER è progettato *blind*: non contiene enumerazioni di tecniche specifiche, lasciando che il modello sviluppi autonomamente criteri di valutazione basati sul contenuto dell'email.

Il dataset di email legittime comprende 600 email (50 per archetipo), generate sinteticamente con saluti generici (senza nome del destinatario) per evitare che la personalizzazione influenzi artificialmente la click probability del TARGET. Ogni email è strutturata con mittente, oggetto, corpo e link opzionale, coerenti con le comunicazioni tipiche del settore dell'archetipo di riferimento.